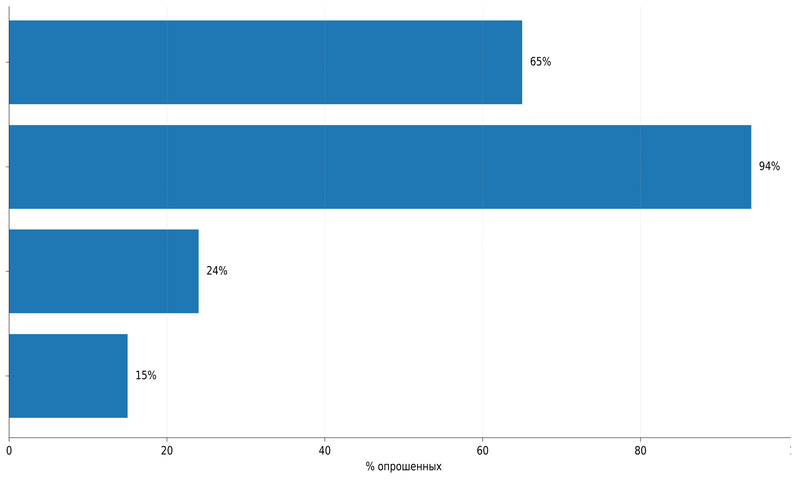
Безопастное развертывание кластеров в инфраструктуре

(Cluster-Audit: in-cluster аудит мисконфигов Pod/Node, RBAC и сети)

Blue Team

Positive Technologies про контейнеризацию в России



Контейнеризация:

- **65%** компаний используют контейнеры для развертывания приложений
- **94%** не фиксированили серьезных инцидентов, часто из-за нехватки видимости
- **24%** используют отечественные средства ИБ для контейнеров
- **15%** используют open-source

Актуальность и пример атаки на k8s

Kubernetes расширяет поверхность атаки: Ingress/Service, CNI, kube-system, хранилища (CSI) и права RBAC. Ошибки конфигурации дают путь к эскалации и утечкам. Cluster-Audit помогает находить риски до инцидента.

Ingress → RCE в Pod → SA token → RBAC-эскалация → Node → kube-system → утечка/закрепление

Похожие продукты

- kube-bench (CIS) - мало про RBAC-цепочки
- kubeaudit - без node-проверок
- Kubescape - тяжелый в эксплуатации
- kube-hunter - не полный аудит

Принцип работы и цель проекта

Система собирает данные из Kube-API (Pods, RBAC, сеть, сервисы/ingress) и при необходимости с нод через Node-Agent (sysctl, IMDS, kubelet/CRI). Затем строится контекст прав и сети (RBAC-граф), выполняются проверки Pod/Node/RBAC, и формируется риск-оценка с отчётом, рекомендациями и YAML-патчами

Автоматизировать аудит безопасности кластера прямо изнутри и заранее находить критичные мисконфиги и избыточные права

Ключевые проверки

- Pod: привилегии, доступ к host, запрет эскалации, профили безопасности.
- RBAC: лишние права (*), доступ к Secrets/exec/nodes, пути эскалации.
- Сеть: нет deny-by-default, открытые Ingress/NodePort, опасный egress (IMDS).
- Node: параметры kubelet/CRI, sysctl-hardening, доступность IMDS.

Выбор технологий

- Язык: **Go**
- API: **client-go**
- Деплой: Docker
- Отчеты: HTML, JSON, SARIF
- Сбор фактов: K8s API + node agent
- Стенд: **kind**

Результат работы in-cluster инструмента


```
{
  "checkId": "K8S-POD-005",
  "severity": "MEDIUM",
  "resource": {
    "kind": "Pod",
    "namespace": "lab-vuln",
    "name": "secrets-in-env-85d9b7b965-gj7h5"
  },
  "title": "Seccomp профиль не установлен",
  "evidence": "container \"app\": seccompProfile not set",
  "risk": "Отсутствие seccomp расширяет набор доступных syscalls",
  "recommendation": "Использовать RuntimeDefault или Localhost профиль"
},
```


Сбор информации об уязвимостях кластера с логированием и последующей упаковкой в JSON

Как использовать

Добавить worker-а в кластер
$ kubectl apply -f audit-job.yaml

Запустить и получить отчет
$ kubectl -n audit job/k8s/audit > report.json

Плюсы

- Развертывание внутри кластера
- минимум зависимостей
- понятный отчет с риском

Минусы

- Не заменяет рантайм-детект и пентест